

# **GRC102: INFORMATION SECURITY GOVERNANCE**

Week 2: Practical Laboratory

**Khadija Muazu Khalil**

**C11/cgrce/26/17559**

International Cybersecurity and Digital Forensics Academy

**ICDFA**

**September 2026**

## TASK 1: ESTABLISH THE SECURITY POLICY HIERARCHY

The IT Director, Sarah Jenkins, has confused policy with procedure: the existing “Password Policy” document mixes management intent with step-by-step Active Directory instructions. This section defines the four-tier documentation hierarchy, classifies the eight draft statements from the brainstorming list, and presents the hierarchy visually.

### 1.1 Hierarchy Definition Table

| Document Type | Purpose                                                                                                                   | Authority / Owner                                                    | Mandatory or Recommended                 | Level of Detail                                                                      |
|---------------|---------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|------------------------------------------|--------------------------------------------------------------------------------------|
| Policy        | States “what” must be achieved and “why” it matters; defines organizational intent, position and high-level requirements. | Executive management / CEO / Information Security Steering Committee | Mandatory                                | Low — broad principles; no technical or configuration detail.                        |
| Standard      | Defines specific, measurable minimum requirements that support and operationalize a policy.                               | IT / Information Security Management                                 | Mandatory                                | Medium — concrete, testable requirements (e.g., encryption method, password length). |
| Guideline     | Offers recommended approaches and best practices for meeting policy or standard intent.                                   | IT / Information Security team                                       | Recommended (discretionary)              | Medium — advisory; allows professional judgments in application.                     |
| Procedure     | Specifies exactly “how” to carry out a task in support of policies and standards.                                         | Operational / technical teams (e.g., IT Helpdesk,                    | Mandatory when tied to a policy/standard | High — detailed, sequential, technical, task-level instructions.                     |

| Document Type | Purpose | Authority / Owner      | Mandatory or Recommended | Level of Detail |
|---------------|---------|------------------------|--------------------------|-----------------|
|               |         | System Administrators) | requiring compliance     |                 |

## 1.2 Categorization of the Eight Draft Statements

Each brainstorming statement was classified according to its language (“must” vs. “should” vs. “it is recommended”), its level of technical detail, and whether it expresses intent, a measurable requirement, an optional practice, or a sequential action.

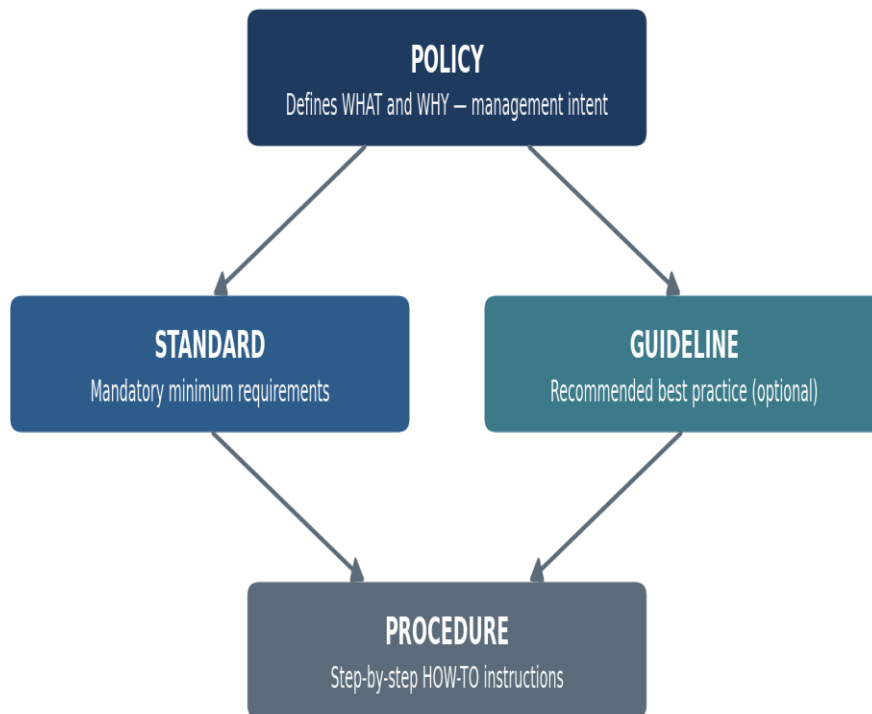
|   | Statement                                                                                                 | Classification | Justification                                                                                                                                                              |
|---|-----------------------------------------------------------------------------------------------------------|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | All NexusTech employees must use MFA when accessing the corporate network remotely.                       | Policy         | States a high-level mandatory requirement (“what” must happen) without specifying any technical configuration — the hallmark of a policy statement.                        |
| 2 | To configure MFA on your mobile device, download the app, scan the QR code, and enter the six-digit code. | Procedure      | Provides sequential, task-level “how-to” instructions for a specific technical action — this is exactly the operational detail a procedure should contain.                 |
| 3 | It is recommended that developers use parameterised queries to reduce SQL injection risk.                 | Guideline      | The phrase “it is recommended” signals an optional best practice rather than a mandatory rule, placing it in the guideline category.                                       |
| 4 | NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.  | Policy         | A broad statement of organizational commitment and intent (“why it matters”) with no measurable requirement or technical detail — typical of a policy's opening statement. |

|   | Statement                                                                                                                                           | Classification | Justification                                                                                                                                              |
|---|-----------------------------------------------------------------------------------------------------------------------------------------------------|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5 | All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or File Vault (macOS).                                       | Standard       | Specifies a mandatory, measurable, technology-specific requirement that supports a broader policy — the defining characteristic of a standard.             |
| 6 | Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.                                                              | Guideline      | The word “should” indicates a recommended behavior rather than an enforceable mandate, consistent with a guideline.                                        |
| 7 | In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.                                  | Procedure      | Gives a single, concrete, immediate action to perform in a defined scenario — an operational instruction rather than a statement of policy intent.         |
| 8 | Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character. | Standard       | Defines a mandatory, measurable minimum requirement with precise technical parameters, supporting the broader Access Control / Enterprise Security Policy. |

### 1.3 Security Documentation Hierarchy Diagram

The diagram below shows how a policy's high-level intent flows down into mandatory standards and optional guidelines, which are in turn operationalized through step-by-step procedures.

## NexusTech Security Documentation Hierarchy



*Policies set direction → Standards and Guidelines translate direction into requirements and recommendations → Procedures operationalise them into concrete, repeatable action.*

## TASK 2: ACCEPTABLE USE POLICY

---

NexusTech currently has no formal Acceptable Use Policy, which has contributed to rising malware and compliance risk from unauthorized software downloads and excessive personal use. The complete policy below defines what users must and must not do, without descending into technical procedure.

### Document Control

|                    |                                       |
|--------------------|---------------------------------------|
| Title              | Acceptable Use Policy                 |
| Version            | 1.0                                   |
| Policy Owner       | Information Security Manager          |
| Approval Authority | Marcus Vance, Chief Executive Officer |
| Effective Date     | 19 September 2026                     |
| Review Date        | 19 September 2027                     |
| Classification     | Internal — All Staff                  |

### 1. Purpose

This Acceptable Use Policy (“AUP”) establishes the rules governing acceptable and responsible use of NexusTech Solutions' (“NexusTech”) information systems, networks, devices, applications and data. It exists to protect the confidentiality, integrity and availability of company and client information, reduce the risk of malware infection, data loss and regulatory non-compliance, and set clear expectations for employee conduct when using corporate IT resources.

### 2. Scope

This policy applies to all NexusTech employees, contractors, interns and third parties (“Users”) who are granted access to NexusTech-owned or NexusTech-managed devices, networks, applications, email systems, cloud services and data, regardless of physical location. It covers company-owned devices and any approved personally-owned device used to access corporate resources, and applies at all times such resources are in use, whether during or outside normal business hours.

### 3. Policy Statements

### **3.1 Acceptable Use**

- Users must use NexusTech systems, networks and devices primarily to support their assigned job responsibilities.
- Users must protect their login credentials at all times and must not share accounts or passwords with any other person.
- Users must lock or log off workstations and devices whenever they are left unattended.
- Users must only install software approved by IT/Security or obtained through the approved software catalogue.
- Users must report lost or stolen devices, suspected malware, phishing attempts or any suspected security incident to the IT Helpdesk immediately.
- Users must apply security updates and patches promptly when prompted by IT-managed systems.

### **3.2 Prohibited Activities**

- a. Use corporate systems for illegal activity, harassment, discrimination, or the creation or distribution of offensive material.
- b. Download, install or execute unauthorized or unlicensed software, including peer-to-peer file-sharing applications.
- c. Disable, bypass or attempt to circumvent security controls, including antivirus software, endpoint protection, multi-factor authentication or full-disk encryption.
- d. Transmit, store or process client data, confidential business information or personal data using unauthorized personal cloud storage, personal email accounts or removable media.
- e. Connect unapproved personal devices to the corporate network without prior authorization from IT/Security.
- f. Share confidential company or client information with unauthorized internal or external parties.
- g. Register for non-business third-party services using corporate credentials without prior approval.

### **3.3 Reasonable Personal Use**

- a. Limited, incidental personal use of corporate email and internet access is permitted, provided it does not interfere with job performance, consume excessive network resources, violate this policy, or expose NexusTech to legal, financial or reputational risk.

- b. Personal use must never involve prohibited content or storage of significant volumes of personal data on corporate systems.
- c. NexusTech reserves the right to monitor use of its systems in accordance with applicable law and the company's monitoring notice.

#### 4. Roles and Responsibilities

| Role                                        | Responsibility                                                                                                                                                                                   |
|---------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Users                                       | Comply with this policy, complete required training, report incidents promptly, and use only approved software and services.                                                                     |
| IT / Security Team                          | Maintain technical controls supporting this policy (endpoint protection, MFA, monitoring), investigate reported violations, maintain the approved software catalogue, and support user training. |
| Managers                                    | Reinforce policy expectations within their teams, review and endorse legitimate business exceptions in consultation with IT/Security, and escalate repeated violations to HR.                    |
| HR                                          | Support disciplinary processes arising from confirmed violations and incorporate AUP acknowledgement into onboarding and periodic review cycles.                                                 |
| Information Security Manager (Policy Owner) | Maintains, reviews and updates this policy, approves exceptions, and reports on compliance to the CEO and Steering Committee.                                                                    |

#### 5. Compliance and Enforcement

- Compliance with this policy is mandatory for all Users as a condition of continued access to NexusTech systems.
- Violations may be identified through automated monitoring, audits, incident investigations, or manager or peer reporting.
- Confirmed violations may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where illegal activity is involved.

- Minor, first-time or inadvertent violations will typically be addressed through coaching and additional training rather than immediate formal discipline, at management's discretion in consultation with IT/Security and HR.

## 6. Exceptions

- Any exception to this policy must be submitted in writing to the Information Security Manager, including business justification and proposed compensating controls.
- Exceptions must be time-limited, recorded in the central exceptions register, and are subject to periodic review.
- Exceptions do not take effect until formally approved in writing by the Information Security Manager or a delegated authority.

## 7. Approval and Review

This policy is approved by Marcus Vance, Chief Executive Officer, with an effective date of 19 September 2026. The Information Security Manager will review this policy annually, or earlier where triggered by significant organizational, technological or regulatory change, with any updates approved through the same authority that approved this version.

## TASK 3: USER ACCESS REQUEST PROCEDURE

---

The Helpdesk currently provisions access based on informal emails and chat messages, creating inconsistent permissions and unauthorized-access risk. The following procedure gives IT Helpdesk technicians a consistent, auditable, sequential process to follow for every access request.

### Document Control

|          |                                                    |
|----------|----------------------------------------------------|
| Title    | User Access Request Procedure                      |
| Version  | 1.0                                                |
| Supports | Access Control Policy; Acceptable Use Policy       |
| Owner    | IT Helpdesk Manager / Information Security Manager |

|          |                         |
|----------|-------------------------|
| Audience | IT Helpdesk Technicians |
|----------|-------------------------|

## 1. Purpose and Scope

This procedure describes the sequential steps IT Helpdesk technicians must follow when provisioning, modifying or revoking user access to NexusTech systems, applications and data. It applies to all requests for new access, changes to existing access, and access removal for employees, contractors and authorized third parties.

## 2. Prerequisites

- a. The requestor must have an active NexusTech employment or contractor record in the HR/Identity system.
- b. Access requests must be submitted through the approved IT Service Management (ITSM) ticketing system — requests made informally by email or chat are not accepted.
- c. The Helpdesk technician must hold an active Helpdesk technician role in the ITSM system and have completed access-provisioning training.
- d. A current Role-Based Access Control (RBAC) matrix must be available for reference.

## 3. Procedure Steps

### Step 1 — Request Intake

- Receive the access request exclusively through the ITSM ticketing system.
- Confirm the ticket includes the requestor name, employee ID, system/application requested, business justification, and requested access level.
- If any required field is missing, return the ticket to the requestor for completion before proceeding.

### Step 2 — Verification of Approval

- Confirm the request has been approved by the requestor's line manager and, where applicable, the relevant system/data owner, via the ITSM approval workflow.
- Do not proceed if approval is missing, expired, or from an unauthorized approver.
- For access to sensitive or regulated data (e.g., client financial or health data), confirm additional Information Security Manager sign-off before continuing.

### **Step 3 — Role-Based and Least-Privilege Check**

- Cross-reference the requested access against the current RBAC matrix for the employee's job role.
- Confirm the requested access aligns with the principle of least privilege; flag any request exceeding standard role permissions for additional review.
- Escalate any mismatch or excessive request to the Information Security Manager before provisioning.

### **Step 4 — Account Creation / Modification**

- Create or modify the account in the relevant Identity and Access Management (IAM) system using standard naming conventions.
- Assign only the approved role-based permission set; do not assign ad-hoc or manually customized permissions outside the RBAC matrix without documented Information Security Manager approval.
- Enable MFA enrolment for the account where applicable, in accordance with the Enterprise Security Policy.

### **Step 5 — User and Manager Notification**

- Notify the requesting user that access has been provisioned, including any required next steps (e.g., MFA setup).
- Notify the requestor's manager that the request has been completed.

### **Step 6 — Evidence Capture and Ticket Closure**

- Attach evidence of approval, the RBAC reference used, and confirmation of account creation to the ITSM ticket.
- Update the ticket status to “Completed” and close within the target service level (e.g., two business days from approval).

### **Step 7 — Emergency or Exceptional Requests**

- For emergency access required outside normal approval timelines (e.g., active incident response), the Information Security Manager or designated on-call authority may grant temporary emergency access.
- Emergency access must be time-limited (maximum 24 hours unless formally extended) and automatically reviewed and re-validated or revoked at expiry.

- Log a retrospective approval and justification in the ITSM system within one business day of the emergency grant.

### Step 8 — Record Retention and Audit Trail

- Retain all access request tickets, approvals and provisioning evidence for a minimum of three years to support audit and compliance requirements.
- Ensure access logs and ticket records remain available for periodic access review and external audit (e.g., SOC 2, ISO/IEC 27001).

## TASK 4: COMMUNICATION AND TRAINING PLAN

---

The CEO has approved the AUP and the User Access Request Procedure. Emailing a PDF is not sufficient for adoption, so the plan below defines audiences, messaging, channels, timing, acknowledgement, and success measures for the rollout.

### 4.1 Communication and Training Matrix

| Audience          | Key Message                                                                                                         | Channel                                                           | Owner                                                        | Timing                                                        | Acknowledgement                                                                | Success Measure                                                                              |
|-------------------|---------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------|---------------------------------------------------------------|--------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| General Employees | The AUP defines what you can and cannot do with company devices, accounts and data — and where to report incidents. | All-hands town hall; mandatory e-learning module; intranet notice | Information Security Manager (content) ; HR (LMS assignment) | Week 1: announcement & town hall; Week 2: complete e-learning | Digital attestation in the LMS confirming the AUP has been read and understood | E-learning completion rate $\geq 95\%$ within 2 weeks; knowledge-check pass rate $\geq 80\%$ |

| <b>Audience</b>         | <b>Key Message</b>                                                                                                                  | <b>Channel</b>                                                                     | <b>Owner</b>                                                           | <b>Timing</b>                                            | <b>Acknowledgement</b>                                      | <b>Success Measure</b>                                                                          |
|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|------------------------------------------------------------------------|----------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| IT Staff                | IT staff must enforce and model AUP compliance and support the technical controls (MFA, endpoint protection, exceptions) behind it. | Technical briefing session; updated internal run books; team channel (Slack/Teams) | IT Director (Sarah Jenkins)                                            | Week 1: technical briefing, ahead of the general rollout | Sign-off on run book review plus briefing attendance record | Run book adoption confirmed at first access audit; drop in AUP-related misconfiguration tickets |
| Management / Leadership | Managers must reinforce AUP expectations within their teams, approve legitimate exceptions, and escalate repeated violations.       | Leadership briefing; manager toolkit (FAQ and talking points) by email             | CEO sponsorship (Marcus Vance); Information Security Manager (content) | Week 1: leadership briefing ahead of general rollout     | Manager acknowledgment form returned to HR                  | % of managers completing briefing; number of manager-confirmed team completions                 |
| HR                      | HR must embed AUP acknowledgment into                                                                                               | Process-update meeting; revised                                                    | HR Lead / Information                                                  | Weeks 1–2: process update,                               | HR sign-off on the updated onboarding SOP                   | Onboarding checklist compliance                                                                 |

| <b>Audience</b> | <b>Key Message</b>                               | <b>Channel</b>       | <b>Owner</b>     | <b>Timing</b>        | <b>Acknowledgement</b> | <b>Success Measure</b> |
|-----------------|--------------------------------------------------|----------------------|------------------|----------------------|------------------------|------------------------|
|                 | onboarding and track ongoing compliance records. | onboarding checklist | Security Manager | ahead of next intake |                        | rate for new hires     |

## 4.2 Rollout Timeline

- i. Week 1: CEO announcement email; leadership and IT technical briefings; company-wide town hall.
- ii. Week 2: Mandatory e-learning module and knowledge-check quiz released to all employees; manager toolkit distributed.
- iii. Week 3: Acknowledgement deadline; automated reminders sent to employees who have not yet completed the module.
- iv. Week 4: Compliance report presented to the Information Security Steering Committee; follow-up training scheduled for non-completers; lessons-learned review.

## 4.3 Escalation of Non-Compliance or Misunderstanding

- i. Employees who miss the acknowledgement deadline receive an automated reminder, followed by a manager-escalation notice if still incomplete.
- ii. Repeated non-completion, or repeated policy misunderstanding evidenced by knowledge-check failures or violations, is escalated to the employee's manager and HR for coaching or disciplinary follow-up, per Section 5 of the AUP.
- iii. A systemic pattern of misunderstanding across a team or department is escalated to the Information Security Steering Committee to determine whether the training approach, or the policy itself, requires revision.

## TASK 5: POLICY REVIEW AND MAINTENANCE MEMO

---

**To :** Information Security Steering Committee

**From :** Information Security Manager, NexusTech Solutions

**Date :** 18 September 2026 (one year after initial AUP rollout)

**Re :** Early Review Trigger — Acceptable Use Policy (AUP) v1.0

NexusTech's recent migration of its primary database to AWS and a security incident in which an employee shared a sensitive document through a personal cloud storage account both constitute formal early-review triggers for the Acceptable Use Policy. The cloud migration materially changes the technical environment the AUP was written for, introducing new data storage locations and shared-responsibility considerations with our cloud provider, while the personal-cloud-sharing incident indicates the AUP's existing restriction on personal cloud storage was either unclear, insufficiently reinforced through training, or inconsistently enforced. Under our policy governance framework, a material change to core infrastructure and a security incident linked directly to a policy area each independently justify a review ahead of the scheduled annual date.

The review will proceed in four stages:

- i. Stakeholder consultation with IT/Cloud Engineering to document how the AWS migration affects the data flows and storage locations the AUP covers
- ii. A focused root-cause analysis of the personal-cloud-sharing incident, determining whether it stemmed from a policy gap, a training gap, or a monitoring gap
- iii. Review of exception records and Helpdesk incident logs from the past twelve months to identify related patterns circulation of proposed AUP amendments to IT, HR, Legal and the Steering Committee for comment prior to formal revision and approval.

Based on preliminary analysis, I recommend at least two updates to the AUP:

- a. Explicitly naming approved cloud storage services including the new AWS-hosted environment and reiterating, with clearer examples, the prohibition on personal cloud accounts for company or client data.
- b. Adding a data-handling clause that clarifies the shared-responsibility boundary between NexusTech and its cloud provider.

As Policy Owner, I will coordinate the revision; the resulting AUP v1.1 will require approval from the CEO, consistent with the original approval route. I recommend retaining the existing annual review cycle while formally adopting two standing early-review triggers for future use: any material change to core infrastructure (such as a cloud migration or major new system), and any policy-related security incident rated medium severity or higher.